

Целостность сообщений

Message Authentication Code (MAC)

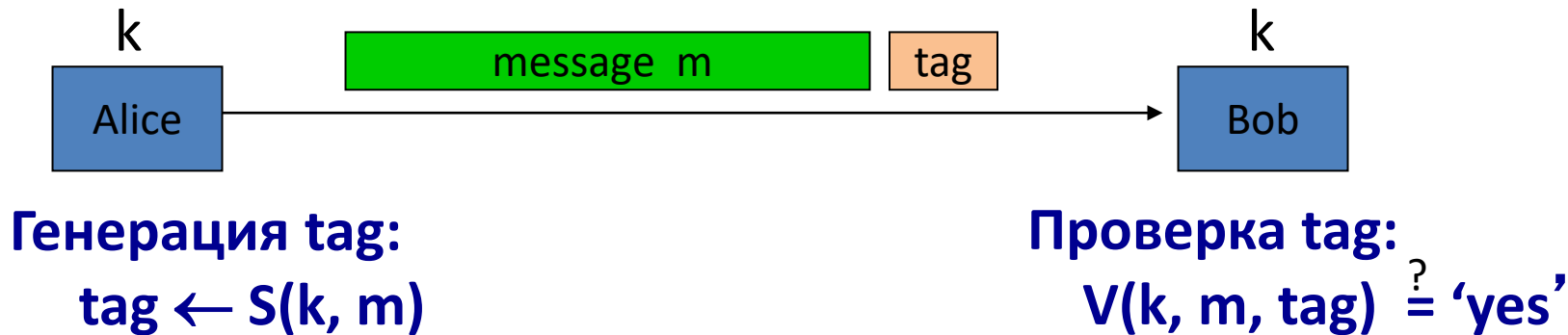
Целостность сообщений

Цель: обеспечение целостности (без конфиденциальности)

Примеры:

- Защита публичных файлов на диске.
- Защита баннеров на веб-страницах.
- ...

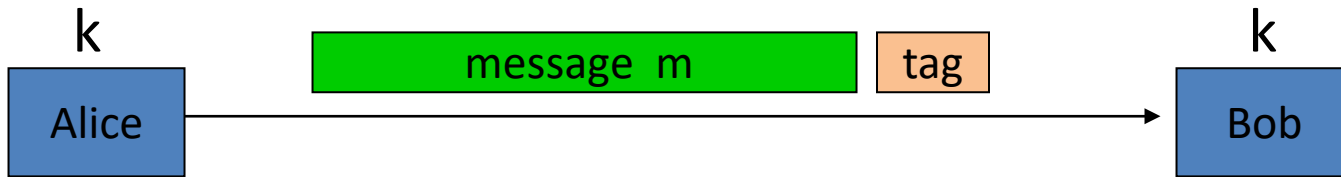
Механизм обеспечения целостности: MACs



Df: **MAC** есть пара алгоритмов $I = (S, V)$ определенных на (K, M, T)

- 1) $S(k, m)$ выводит t из T
- 2) $V(k, m, t)$ выводит 'yes' или 'no'

Механизм обеспечения целостности: MACs



Генерация tag:
 $\text{tag} \leftarrow S(k, m)$

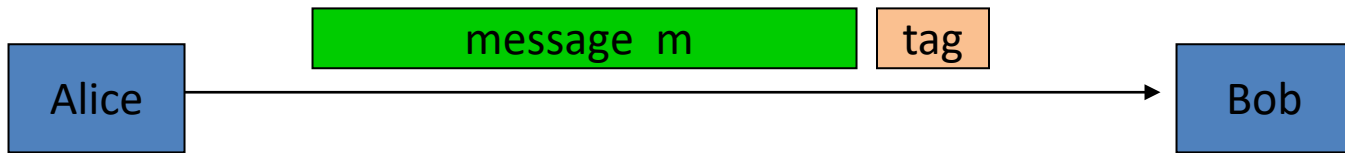
Проверка tag:
 $V(k, m, \text{tag}) \stackrel{?}{=} \text{'yes'}$

Df: **MAC** есть пара алгоритмов $I = (S, V)$ определенных на (K, M, T)

- 1) $S(k, m)$ выводит t из T
- 2) $V(k, m, t)$ выводит 'yes' или 'no'

Требование согласованности: $V(k, m, S(k, m)) = \text{'yes'}$

Для обеспечения целостности требуется секретный ключ



Генерация tag:
 $\text{tag} \leftarrow \text{CRC}(m)$

Проверка tag:
 $V(m, \text{tag}) \stackrel{?}{=} \text{'yes'}$

- Противник может легко модифицировать сообщение m и повторно вычислить CRC (cyclic redundancy check – контрольные суммы).
- CRC спроектирован для выявления случайных, а не злонамеренных ошибок.

Безопасность MACs

Возможности противника: **chosen message attack** (выбранная атака на сообщение)

- Для сообщений $m_1, m_2, \dots, m_q$ противник может получить $t_i \leftarrow S(k, m_i)$

Цель противника: **existential forgery** (экзистенциальная подделка)

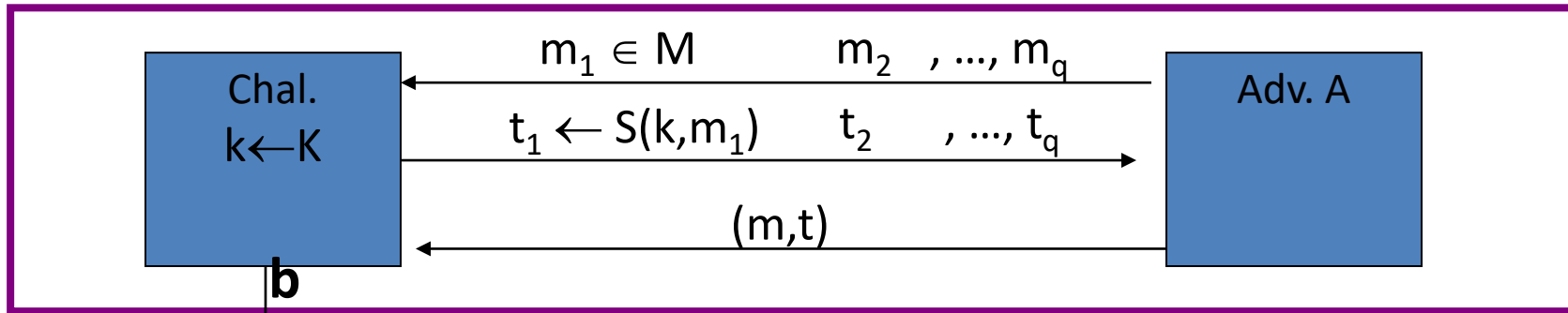
- сгенерировать новую допустимую пару message/tag (m, t) :

$$(m, t) \notin \{ (m_1, t_1), \dots, (m_q, t_q) \}$$

$\Rightarrow$ противник не может сгенерировать tag t для нового сообщения

Безопасность MACs

Для MAC $I=(S,V)$ и противника A определим MAC-игру след. образом:



$$\begin{cases} b=1 & \text{если } V(k, m, t) = \text{'yes'} \text{ и } (m, t) \notin \{(m_1, t_1), \dots, (m_q, t_q)\} \\ b=0 & \text{в противном случае} \end{cases}$$

Df: $I=(S,V)$ явл-ся безопасным MAC если для любого “эффективного” A :

$$\text{Adv}_{\text{MAC}}[A, I] = \Pr[b=1] < \text{“пренебрежимо мало”}$$

Имеем MAC $I = (S, V)$.

Предположим, противник А может найти $m_0 \neq m_1$ такую что

$$S(k, m_0) = S(k, m_1) \quad \text{для } \frac{1}{2} \text{ ключей } k \text{ в } K$$

Может ли этот MAC быть безопасным?

- ☐ Да, А не может создать допустимый tag для m_0 или m_1
- ☐ Нет, этот MAC может быть вскрыт с исп. chosen msg attack
- ☐ Зависит от деталей реализации MAC
- ☐

Имеем MAC $I = (S, V)$.

Предположим, противник A может найти $m_0 \neq m_1$ такую что

$$S(k, m_0) = S(k, m_1) \quad \text{для } \frac{1}{2} \text{ ключей } k \text{ в } K$$

Может ли этот MAC быть безопасным?

- ☐ Да, A не может создать допустимый tag для m_0 или m_1
- ☐ Нет, этот MAC может быть вскрыт с исп. chosen msg attack
- ☐ Зависит от деталей реализации MAC
- ☐

$$\text{Adv}[A, I] = 1/2$$

Имеем MAC $I = (S, V)$.

Предположим $S(k, m)$ всегда имеет длину 5 бит

Может ли этот MAC быть безопасным?

- ☐ Нет, противник может просто угадать tag для сообщений
- ☐ Зависит от деталей реализации MAC
- ☐ Да, А не может создать допустимый tag для любого m
- ☐

Имеем MAC $I = (S, V)$.

Предположим $S(k, m)$ всегда имеет длину 5 бит

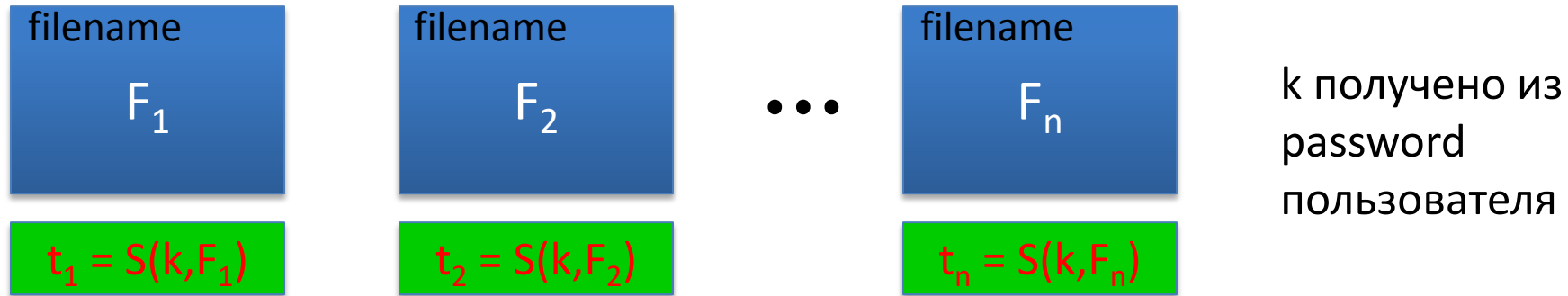
Может ли этот MAC быть безопасным?

- ☐ Нет, противник может просто угадать tag для сообщений
- ☐ Зависит от деталей реализации MAC
- ☐ Да, А не может создать допустимый tag для любого m
- ☐



Пример: защита системных файлов

Предположим, во время установки система вычисляет:



Впоследствии вирус инфицирует систему и модифицирует системные файлы

Пользователь перезагружается с чистой ОС и вводит свой пароль (password)

Тогда из безопасности MAC $\Rightarrow$ все модифицированные файлы будут обнаружены

Обеспечение целостности

MACs на основе PRF

Безопасность MACs (повтор)

MAC: алг. подписи $S(k,m) \rightarrow t$ и алг. верификации $V(k,m,t) \rightarrow 0,1$

Возможности противника: **chosen message attack**

- для $m_1, m_2, \dots, m_q$ противник может получить $t_i \leftarrow S(k, m_i)$

Цель противника: **existential forgery** (экзистенциальная подделка)

сгенерировать новую допустимую пару message/tag (m,t) :

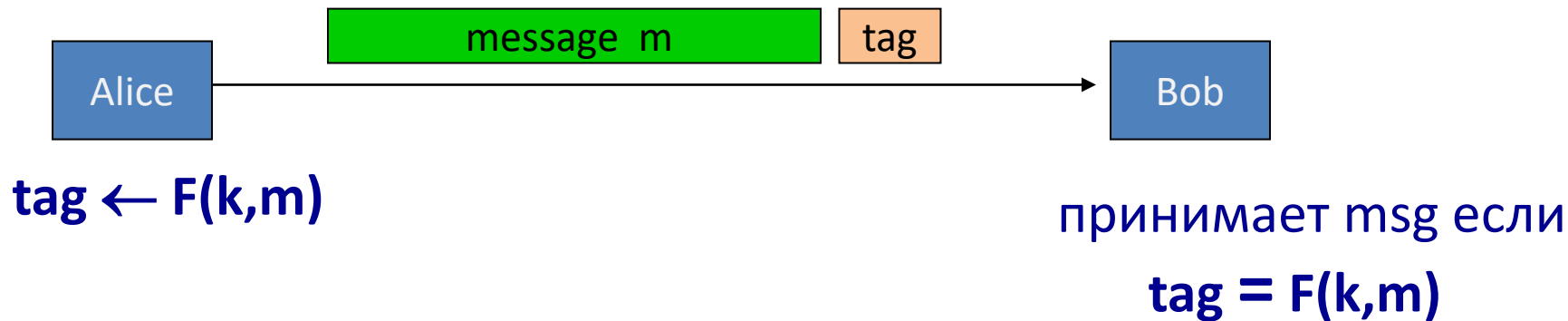
$$(m,t) \notin \{ (m_1, t_1), \dots, (m_q, t_q) \}$$

$\Rightarrow$ противник не может сгенерировать tag t для нового сообщения

Безопасный PRF $\Rightarrow$ Безопасный MAC

Для PRF $F: K \times X \rightarrow Y$ определим MAC $I_F = (S, V)$ след. образом:

- $S(k, m) := F(k, m)$
- $V(k, m, t)$: выводит 'yes' если $t = F(k, m)$, иначе 'no'.



Пример

Пусть $F: K \times X \rightarrow Y$ безопасная PRF с $Y = \{0,1\}^{10}$

Является ли полученная MAC I_F безопасной MAC ?

- ☐ Да, MAC безопасна, так как PRF безопасна
- ☐ Нет, так как tag слишком короткий, можно угадать его
- ☐ Зависит от функции F
- ☐

Пример

Пусть $F: K \times X \rightarrow Y$ безопасная PRF с $Y = \{0,1\}^{10}$

Является ли полученная MAC I_F безопасной MAC ?

- ☐ Да, MAC безопасна, так как PRF безопасна
- ☐ Нет, так как tag слишком короткий, можно угадать его
- ☐ Зависит от функции F
- ☐

$$\text{Adv}[A, I_F] = 1/1024$$

Теорема о безопасности

Теорема: Если $F: K \times X \rightarrow Y$ безопасная PRF и $1/|Y|$ пренебрежимо мало (т.е. $|Y|$ достаточно велико), то I_F явл-ся безопасной MAC.

В частности, для любого эфф. MAC, противника A атакующего I_F существует эфф. PRF F атакующий F , такой что:

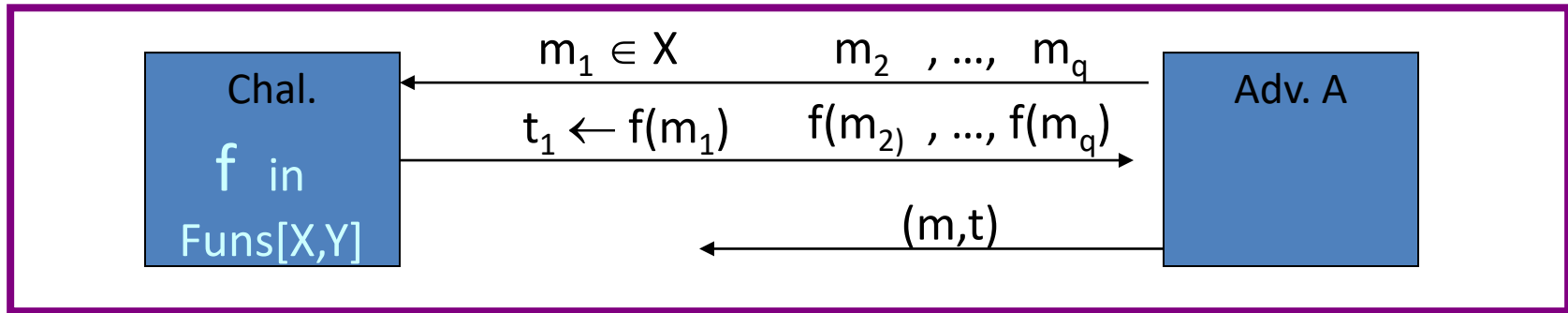
$$\text{Adv}_{\text{MAC}}[A, I_F] \leq \text{Adv}_{\text{PRF}}[B, F] + 1/|Y|$$

$\Rightarrow I_F$ безопасный если $|Y|$ достаточно велико, напр. $|Y| = 2^{80}$.

Схема доказательства

Пусть $f: X \rightarrow Y$ действительно случайная функция

Тогда противник A должен выиграть следующую игру:



Противник A выигрывает если $t = f(m)$ и $m \notin \{m_1, \dots, m_q\}$

$\Rightarrow \Pr[A \text{ выигрывает}] = 1/|Y|$ То же справедливо для $F(k,x)$

Примеры

- AES: MAC для 16-байтовых сообщений.
- Основной вопрос: как конвертировать Small-MAC в Big-MAC ?
- На практике используются две основные конструкции:
 - **CBC-MAC** (– ANSI X9.9, X9.19, FIPS 186-3)
 - **HMAC** (Internet protocols: SSL, IPsec, SSH, ...)
- Обе конструкции основаны на конвертации small-PRF в big-PRF.

Целостность сообщений

СВС-МАС и NMAC

MACs и PRFs

Итак, безопасность PRF $F \Rightarrow$ безопасность MAC,
пока $|Y|$ достаточно велико

$$S(k, m) = F(k, m)$$

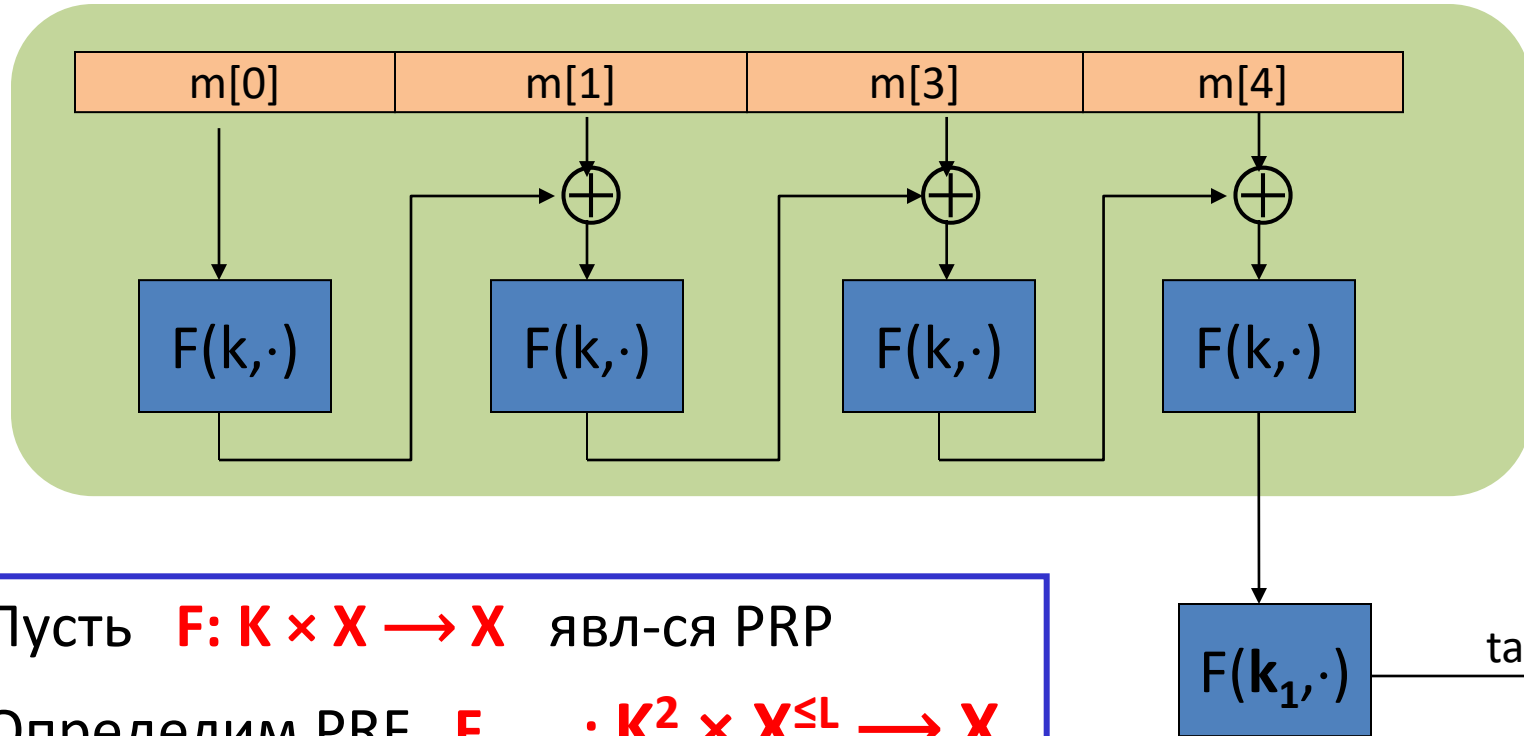
Дальнейшая цель:

исходя из PRF для коротких сообщений (AES)
сконструировать PRF для длинных сообщений

В дальнейшем пусть $X = \{0,1\}^n$ (например, $n = 128$)

Конструкция 1: encrypted CBC-MAC

raw CBC

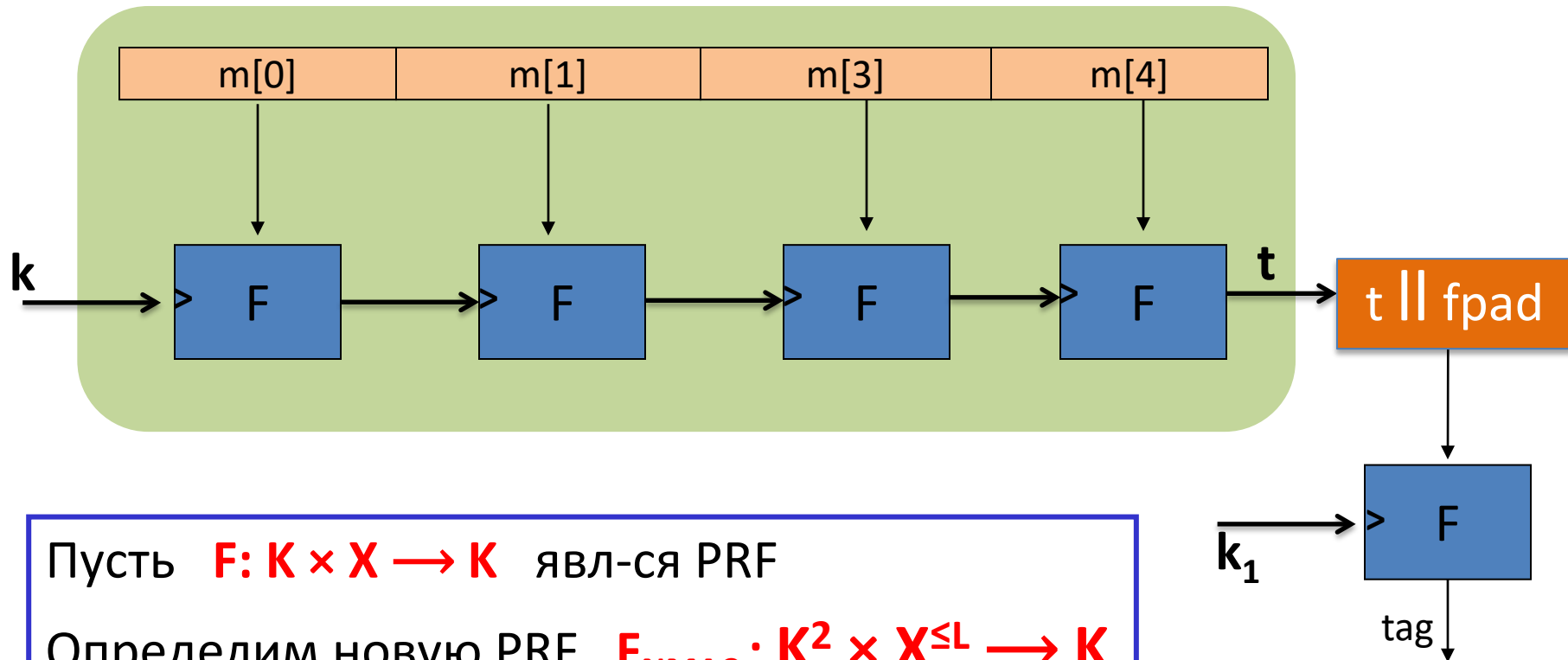


Пусть $F: K \times X \rightarrow X$ явл-ся PRP

Определим PRF $F_{\text{ECBC}}: K^2 \times X^{\leq L} \rightarrow X$

Конструкция 2: NMAC (nested MAC)

cascade



Пусть $F: K \times X \rightarrow K$ явл-ся PRF

Определим новую PRF $F_{\text{NMAC}}: K^2 \times X^{\leq L} \rightarrow K$

Зачем нужен последний этап в ECBC-MAC и NMAC?

NMAC: предположим, мы определили MAC $I = (S, V)$, где

$$S(k, m) = \text{cascade}(k, m)$$

- Этот MAC безопасен
- Этот MAC может быть подделан без chosen msg queries
- Этот MAC может быть подделан с одной chosen msg query
- Этот MAC может быть подделан с двумя chosen msg query

Зачем нужен последний этап в ECBC-MAC и NMAC?

NMAC: предположим, мы определили MAC $I = (S, V)$, где

$$S(k, m) = \text{cascade}(k, m)$$

- Этот MAC безопасен
- Этот MAC может быть подделан без chosen msg queries
- Этот MAC может быть подделан с одной chosen msg query
- Этот MAC может быть подделан с двумя chosen msg query

Подсказка: $\text{cascade}(k, m) \Rightarrow \text{cascade}(k, m \parallel w)$ для любого w



Зачем нужен последний этап в ECBC-MAC?

Предположим, мы определили MAC $I_{\text{RAW}} = (S, V)$, где

$$S(k, m) = \text{rawCBC}(k, m)$$

Тогда I_{RAW} легко вскрываем с использованием 1-chosen msg attack.

Противник действует следующим образом:

- Выбирает произвольное 1-блочное сообщение $m \in X$
- Запрашивает tag для m . Полагает $t = F(k, m)$
- Выдает t как MAC-подделку для 2-блочного сообщения $(m, t \oplus m)$



Зачем нужен последний этап в ECBC-MAC?

Предположим, мы определили MAC $I_{\text{RAW}} = (S, V)$, где

$$S(k, m) = \text{rawCBC}(k, m)$$

Тогда I_{RAW} легко вскрываем с использованием 1-chosen msg attack.

Противник действует следующим образом:

- Выбирает произвольное 1-блочное сообщение $m \in X$
- Запрашивает tag для m . Полагает $t = F(k, m)$
- Выдает t как MAC-подделку для 2-блочного сообщения $(m, t \oplus m)$

Действ-но: $\text{rawCBC}(k, (m, t \oplus m)) = F(k, F(k, m) \oplus (t \oplus m)) = F(k, t \oplus (t \oplus m)) = t$

Анализ ECBC-МАС и NMAC

Теорема: Для любого $L > 0$,

Для любого эфф. противника A атакующего F_{ECBC} или F_{NMAC} существует эфф. противник B такой что:

$$\text{Adv}_{\text{PRF}}[A, F_{\text{ECBC}}] \leq \text{Adv}_{\text{PRP}}[B, F] + 2q^2 / |X|$$

$$\text{Adv}_{\text{PRF}}[A, F_{\text{NMAC}}] \leq q \cdot L \cdot \text{Adv}_{\text{PRF}}[B, F] + q^2 / 2|K|$$

СВС-МАС безопасен при условии $q \ll |X|^{1/2}$

NMAC безопасен при условии $q \ll |K|^{1/2}$ (2^{64} for AES-128)

Пример

$$\text{Adv}_{\text{PRF}}[A, F_{\text{ECBC}}] \leq \text{Adv}_{\text{PRP}}[B, F] + 2q^2 / |X|$$

q = число сообщений, помеченных MAC с ключом k

Пусть мы хотим $\text{Adv}_{\text{PRF}}[A, F_{\text{ECBC}}] \leq 1/2^{32} \quad \Leftrightarrow \quad q^2 / |X| < 1/2^{32}$

- AES: $|X| = 2^{128} \Rightarrow q < 2^{48}$

Поэтому после 2^{48} сообщений необходимо сменить ключ

- 3DES: $|X| = 2^{64} \Rightarrow q < 2^{16}$

Сравнение

ЕСВС-МАС обычно используется как МАС на основе AES

- ССМ код шифрования (used in 802.11i)
- NIST стандарт, называется СМАС

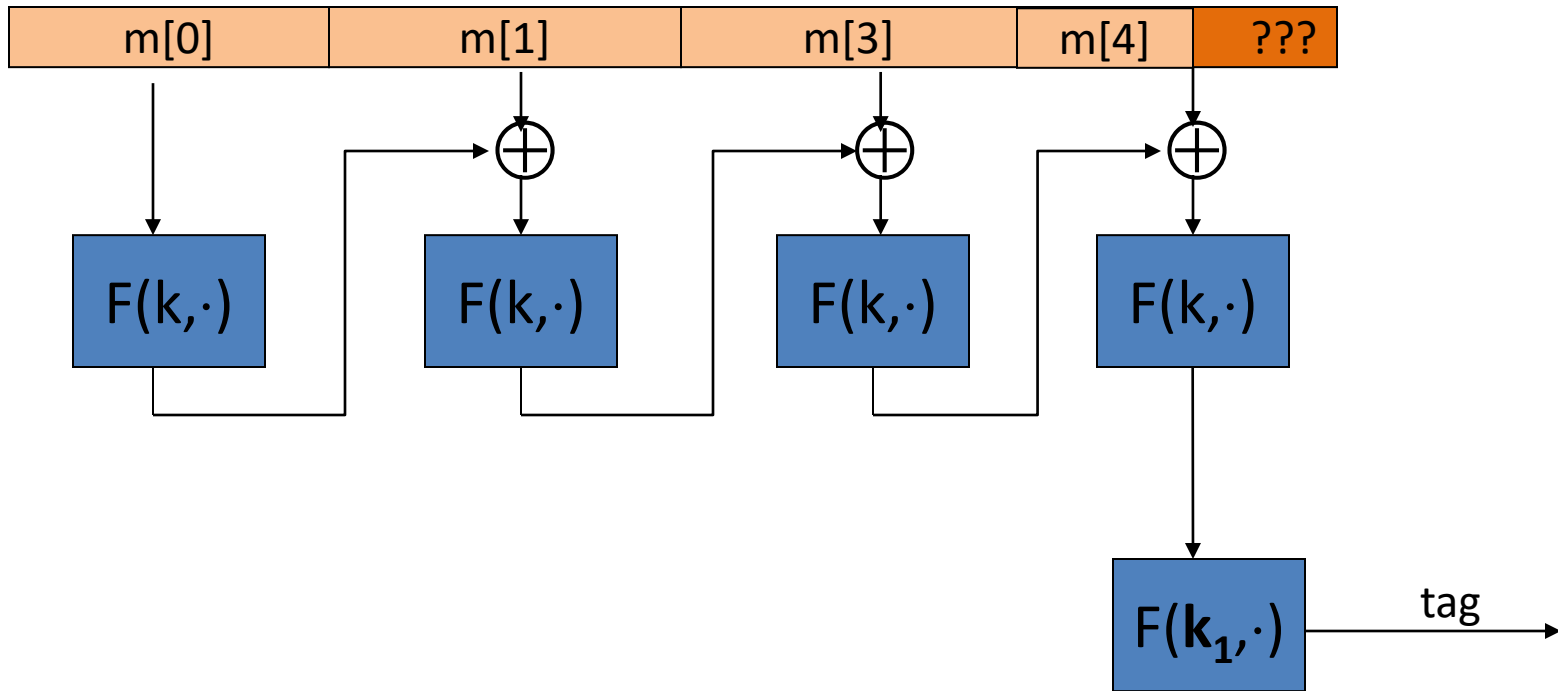
NMAC обычно не используется с AES или 3DES

- NMAC является основой МАС , называемый HMAC

Целостность сообщений

MAC padding

Если длина сообщения не кратна размеру блока?



CBC MAC padding

Плохая идея: дополнить m 0-ми



Является ли полученный MAC безопасным?

- ☐ Да, MAC безопасен
- ☐ Зависит от MAC
- ☐ Нет, имея tag для m противник может получить tag для $m||0$
- ☐

CBC MAC padding

Плохая идея: дополнить m 0-ми



Является ли полученный MAC безопасным?

- ☐ Да, MAC безопасен
- ☐ Зависит от MAC
-  ☒ Нет, имея tag для m противник может получить tag для $m||0$
- ☐

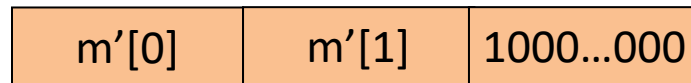
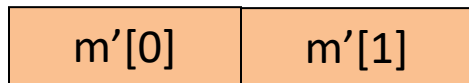
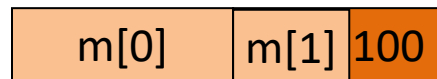
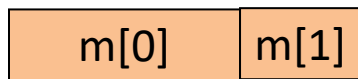
CBC MAC padding

Для безопасности, padding должен быть инвертируемым !

$$m_0 \neq m_1 \Rightarrow \text{pad}(m_0) \neq \text{pad}(m_1)$$

ISO: $\text{pad} = \text{"1000...00"}$. Добавляется новый пустой блок, если необходимо.

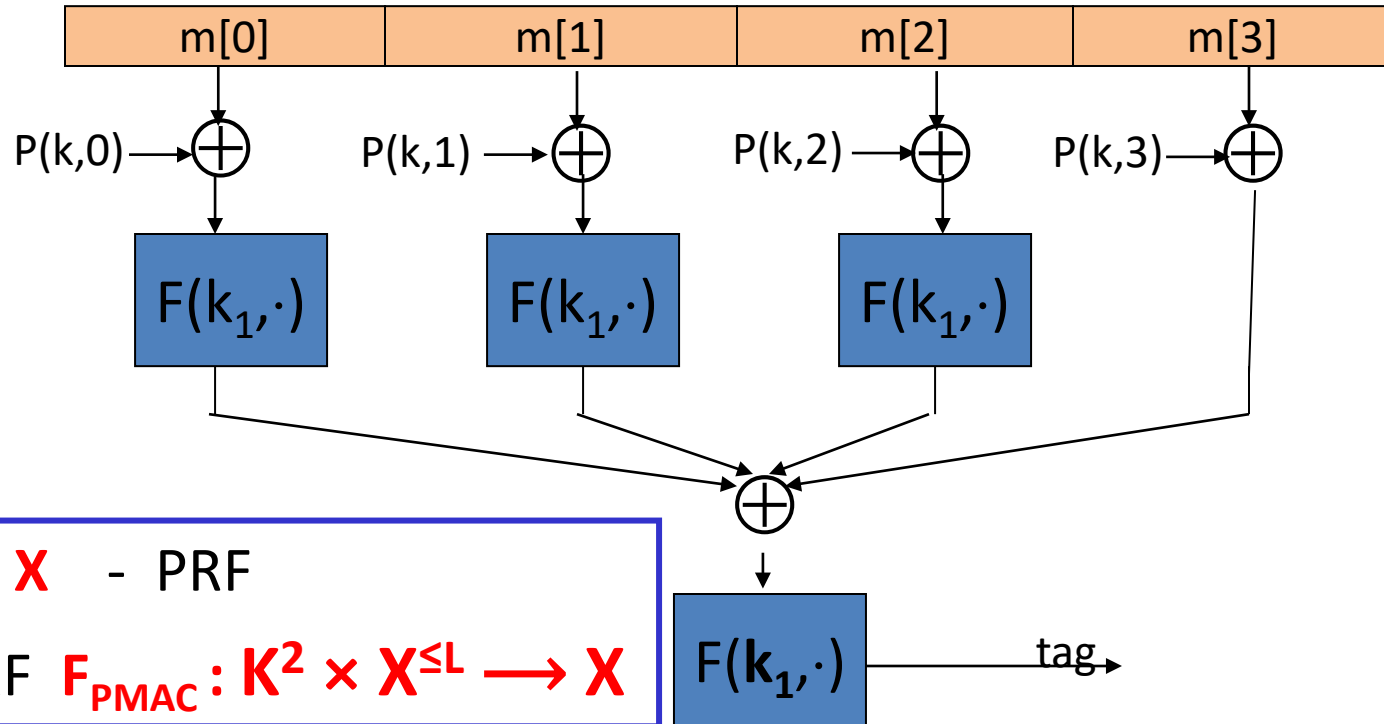
– “1” обозначает начало pad.



Конструкция 3: РМАС – параллельный МАС

$P(k, i)$: легко вычисляемая функция

key = (k, k_1)



Пусть $F: K \times X \rightarrow X$ - PRF

Опред. новую PRF $F_{\text{РМАС}}: K^2 \times X^{\leq L} \rightarrow X$

PMAC Теорема

PMAC Теорема: Для любого $L > 0$,

Если F – безопасная PRF над (K, X, X) , то

F_{PMAC} – безопасная PRF над $(K, X^{\leq L}, X)$.

Для любой эфф. противника A (q -query) атакующего F_{PMAC} существует эффективный PRF B такая что:

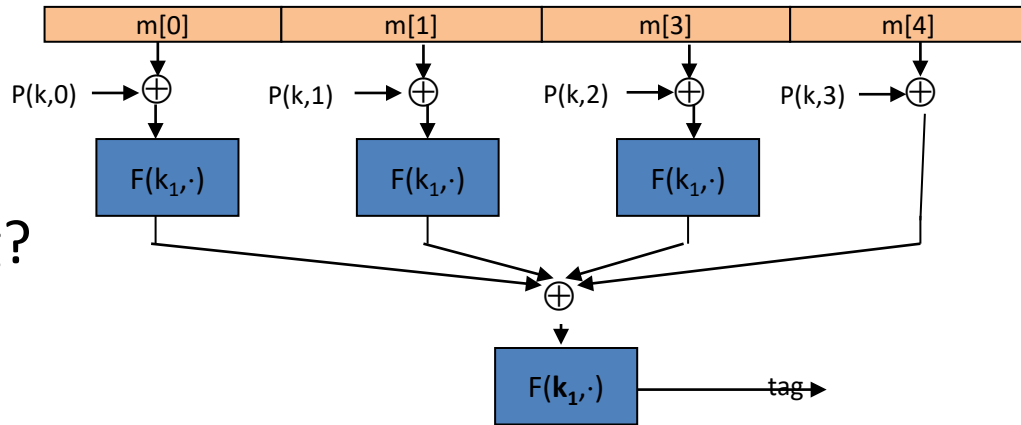
$$\text{Adv}_{\text{PRF}}[A, F_{\text{PMAC}}] \leq \text{Adv}_{\text{PRF}}[B, F] + 2 q^2 L^2 / |X|$$

PMAC is secure as long as $qL \ll |X|^{1/2}$

Небольшая модификация РМАС

Пусть F явл-ся PRP.

Если заменить $m[1] \rightarrow m'[1]$
можно ли быстро обновить tag?



☐ нет, нельзя

☐ do $F^{-1}(k_1, \text{tag}) \oplus F(k_1, m'[1] \oplus P(k,1))$

☐ do $F^{-1}(k_1, \text{tag}) \oplus F(k_1, m[1] \oplus P(k,1)) \oplus F(k_1, m'[1] \oplus P(k,1))$

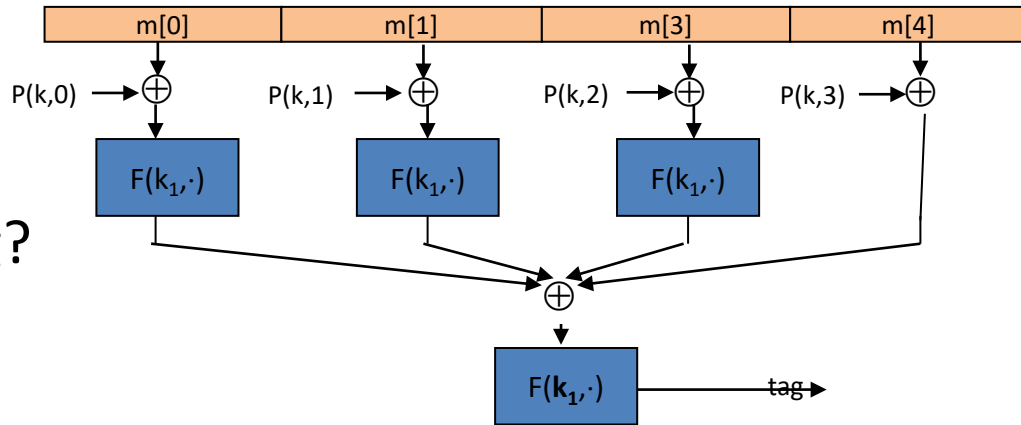
☐ do $\text{tag} \oplus F(k_1, m[1] \oplus P(k,1)) \oplus F(k_1, m'[1] \oplus P(k,1))$

после чего применить $F(k_1, \cdot)$

Небольшая модификация РМАС

Пусть F явл-ся PRP.

Если заменить $m[1] \rightarrow m'[1]$
можно ли быстро обновить tag?



☐ нет, нельзя

☐ do $F^{-1}(k_1, \text{tag}) \oplus F(k_1, m'[1] \oplus P(k,1))$

☐ do $F^{-1}(k_1, \text{tag}) \oplus F(k_1, m[1] \oplus P(k,1)) \oplus F(k_1, m'[1] \oplus P(k,1))$

☐ do $\text{tag} \oplus F(k_1, m[1] \oplus P(k,1)) \oplus F(k_1, m'[1] \oplus P(k,1))$

после чего применить $F(k_1, \cdot)$

Конструкция 4: HMAC (Hash-MAC)

Наиболее распространенный MAC в Интернете.

... построен на основе хэш-функций